

RBAC Security Test Specification

API Access Control & Security Validation Protocol

1. Purpose

This document defines the security tests required to verify Authentication, Role-Based Access Control (RBAC), Financial Data Isolation, Organizational Scope, Privilege Escalation Protection, Auditor Read-only access, and administrative access. The tests will be executed against the final backend API endpoints defined in the OpenAPI contract.

2. Authentication Tests

ID	Test Case	Expected Result
AUTH-01	Access a protected endpoint without authentication	401 Unauthorized
AUTH-02	Access a protected endpoint using an invalid token	401 Unauthorized
AUTH-03	Access a protected endpoint using an expired token	401 Unauthorized
AUTH-04	Login with valid credentials	Authentication successful
AUTH-05	Login with invalid credentials	Authentication rejected

3. Asset Administrator

The Asset Administrator manages the asset registry and authorized asset lifecycle operations.

ID	Endpoint / Action	Expected Result
ADM-01	GET /api/assets	200 OK
ADM-02	POST /api/assets	201 Created
ADM-03	PATCH /api/assets/:id	200 OK
ADM-04	POST /api/assets/import	200 OK
ADM-05	POST /api/assets/:id/transfer	200 OK
ADM-06	POST /api/assets/:id/retire	200 OK
ADM-07	GET /api/invoices/:id	200 OK
ADM-08	PATCH /api/invoices/:id	403 Forbidden
ADM-09	POST /api/work-orders	201 Created
ADM-10	Access an asset outside administrator's organizational scope	403 Forbidden / Denied

4. Procurement / Finance

The Procurement / Finance role manages procurement and financial information but does not manage asset lifecycle.

ID	Endpoint / Action	Expected Result
PRO-01	GET /api/assets/:id	200 OK
PRO-02	GET /api/suppliers	200 OK
PRO-03	POST /api/suppliers	201 Created
PRO-04	POST /api/purchase-orders	201 Created
PRO-05	PATCH /api/purchase-orders/:id	200 OK
PRO-06	GET /api/invoices/:id	200 OK
PRO-07	POST /api/invoices	201 Created
PRO-08	GET /api/warranties/:id	200 OK
PRO-09	PATCH /api/assets/:id	403 Forbidden

5. Custodian / Department Manager

The Custodian / Department Manager can access and manage assets within the assigned organizational scope.

ID	Endpoint / Action	Expected Result
CUS-01	GET /api/assets	200 OK
CUS-02	GET /api/assets/:id within assigned scope	200 OK
CUS-03	GET /api/assets/:id outside assigned scope	403 Forbidden / 404 Not Found
CUS-04	POST /api/assets/:id/confirm-assignment	200 OK
CUS-05	PATCH /api/assets/:id/condition	200 OK
CUS-06	GET /api/invoices/:id	403 Forbidden
CUS-07	GET /api/purchase-orders/:id	403 Forbidden
CUS-08	PATCH /api/assets/:id	403 Forbidden
CUS-09	POST /api/assets/:id/retire	403 Forbidden
CUS-10	Change asset ID to access another department's asset	403 Forbidden / 404 Not Found

6. Maintenance Technician

The Maintenance Technician is authorized to perform maintenance-related operations only.

ID	Endpoint / Action	Expected Result
TECH-01	GET /api/work-orders	200 OK
TECH-02	GET /api/work-orders/:id	200 OK
TECH-03	PATCH /api/work-orders/:id	200 OK
TECH-04	POST /api/work-orders/:id/complete	200 OK
TECH-05	POST /api/work-orders/:id/service	201 Created
TECH-06	GET /api/assets/:id	200 OK
TECH-07	GET /api/invoices/:id	403 Forbidden
TECH-08	PATCH /api/assets/:id	403 Forbidden
TECH-09	POST /api/assets/:id/transfer	403 Forbidden
TECH-10	POST /api/assets/:id/retire	403 Forbidden

7. Auditor

The Auditor is a read-only role and cannot modify business records.

ID	Endpoint / Action	Expected Result
AUD-01	GET /api/assets	200 OK
AUD-02	GET /api/assets/:id	200 OK
AUD-03	GET /api/invoices/:id	200 OK
AUD-04	GET /api/work-orders	200 OK
AUD-05	GET /api/audit-logs	200 OK
AUD-06	POST /api/assets	403 Forbidden
AUD-07	PATCH /api/assets/:id	403 Forbidden
AUD-08	POST /api/assets/:id/transfer	403 Forbidden
AUD-09	POST /api/assets/:id/retire	403 Forbidden

8. Financial Data Isolation Tests

ID	Test Case	Expected Result
FIN-01	Custodian accesses an invoice	403 Forbidden
FIN-02	Maintenance Technician accesses an invoice	403 Forbidden
FIN-03	Custodian accesses purchase cost	403 Forbidden
FIN-04	Maintenance Technician accesses financial cost info not required	403 Forbidden
FIN-05	Procurement / Finance accesses authorized financial info	200 OK
FIN-06	Auditor reads authorized financial references	200 OK
FIN-07	User accesses financial data outside organizational scope	403 Forbidden / Denied

9. Organizational Scope Tests

ID	Test Case	Expected Result
SCOPE-01	User accesses a resource inside assigned scope	Allow
SCOPE-02	User accesses a resource outside assigned scope	Deny
SCOPE-03	User accesses a child organization under assigned scope	Allow
SCOPE-04	User accesses a sibling organization	Deny
SCOPE-05	User with multiple scopes accesses resources within either scope	Allow
SCOPE-06	User attempts to modify their own organizational scope	403 Forbidden
SCOPE-07	User changes resource ID to access another org's asset	403 Forbidden / 404 Not Found
SCOPE-08	User attempts to access financial data outside assigned scope	Deny

10. Privilege Escalation Tests

ID	Test Case	Expected Result
PRIV-01	Maintenance Technician attempts an Asset Administrator action	403 Forbidden
PRIV-02	Custodian attempts a Procurement / Finance action	403 Forbidden
PRIV-03	Auditor attempts to modify a resource	403 Forbidden
PRIV-04	Procurement / Finance attempts to retire an asset	403 Forbidden
PRIV-05	User attempts to modify their own role	403 Forbidden
PRIV-06	User attempts to assign themselves a higher role	403 Forbidden
PRIV-07	User attempts to call an endpoint belonging to another role	403 Forbidden

11. Administrative Access Tests

ID	Test Case	Expected Result
ADMIN-01	Asset Administrator creates an asset	Allow
ADMIN-02	Asset Administrator updates an asset	Allow
ADMIN-03	Asset Administrator imports assets	Allow
ADMIN-04	Asset Administrator transfers an asset	Allow
ADMIN-05	Asset Administrator retires an asset	Allow
ADMIN-06	Unauthorized role attempts asset administration	403 Forbidden
ADMIN-07	Asset Administrator attempts to access resources outside assigned scope	Deny